

Kritik Zafiyet ve Red Team Operasyon Raporu

Hazırlayan: Azizcan Daştan

Tarih: 2 Temmuz 2026

Konu: Ardventures ve Arbitex Altyapısı Ofansif Güvenlik Analizi

1. Yönetici Özeti

Ardventures ve Arbitex platformlarına yönelik gerçekleştirilen dış saldırı yüzeyi analizinde, Docker Registry üzerinden kritik yapılandırma dosyalarının (.env) yetkisiz erişime açık olduğu saptanmıştır. Bu zafiyet, saldırganların altyapı üzerinde "Tam Yetki İhlali" gerçekleştirmesine ve tüm veri katmanlarını manipüle etmesine olanak tanımaktadır. İlgili bulgular, ofansif güvenlik disiplininiz çerçevesinde raporlanmıştır.

2. Teknik İnceleme ve Veri İfşası (Exposure Analysis)

Yapılan analiz sonucunda, aşağıdaki kritik veri setlerinin hiçbir kısıtlama olmaksızın erişilebilir olduğu tespit edilmiştir:

- Veritabanı Kimlik Bilgileri:** PostgreSQL (kitle_fonlama) erişim verileri.
- Cloud Depolama:** MinIO Endpoint ve erişim anahtarları (Storage Hijack).
- Kimlik Doğrulama:** JWT_SECRET, Google Client Secret, SESSION_SECRET.
- API Entegrasyonları:** Telegram, SMTP, SMS, Meta Pixel, Captcha ve MKK API anahtarları.

3. Red Team Tehdit Modellemesi

Bu zafiyet, bir Red Team operatörü için "Sistem Ele Geçirme" (System Takeover) senaryolarının temelini oluşturur:

- Data Exfiltration:** PostgreSQL ve MinIO verilerinin üçüncü taraf sunuculara aktarılması.
- Account Takeover (ATO):** JWT anahtarı ile platformda idari yetkilere sahip olunması.

- **Phishing & Social Engineering:** SMTP ve SMS servislerinin kullanılarak kullanıcıların ortalama saldırılarına maruz bırakılması.

4. Ofansif Aksiyon Planı (90 Günlük Acil Müdahale)

Dönem	Ofansif Aksiyon
0-15 Gün	Tüm API anahtarlarının rotasyonu (Rotate Secrets) ve altyapı sızdırmazlık kontrolleri.
15-45 Gün	Ardventures/Arbitex platformlarında derinlemesine sızma testi (Vulnerability Assessment & Penetration Testing).
45-90 Gün	Kapatılan zafiyetlerin ofansif olarak tekrar test edilmesi ve sistem güçlendirme (Hardening).

5. 12 Aylık Red Team Danışmanlık Stratejisi

Sürekli ve ofansif bir güvenlik duruşu için her çeyrekte tekrarlanacak Red Team operasyonları gerçekleştirilecektir:

- **Çeyrek 1 (Altyapı):** Dış saldırı yüzeyinin (Reconnaissance) ve sistem mukavemetinin ofansif testleri.
- **Çeyrek 2 (İstismar):** Exploit geliştirme, yetki yükseltme ve savunma katmanlarının aşılması.
- **Çeyrek 3 (Sosyal Mühendislik):** Platform içi phishing senaryoları ve kullanıcı/ personel farkındalık simülasyonları.
- **Çeyrek 4 (APT Simülasyonu):** Advanced Persistent Threat (APT) senaryoları ile sistemin uzun vadeli ofansif direncini ölçme.

Bu rapor, Azizcan Daştan tarafından Red Team standartlarına uygun olarak, şirketin ofansif güvenlik açığını kapatmak amacıyla hazırlanmıştır.